

SECUREPAY SOLUTIONS PVT. LTD.

PASSWORD & MULTI-FACTOR AUTHENTICATION POLICY

Policy ID: SP-GRC-POL-002 | Version: 1.0 | Status: Draft / Portfolio Sample

Policy Owner	Information Security / GRC
Effective Date	September 2026
Review Frequency	At least annually and after significant changes
Classification	Internal – Simulated

Portfolio disclaimer: SecurePay Solutions Pvt. Ltd. is fictional. This document is a simulated policy created for educational and portfolio purposes and is not an approved policy of a real organization.

1. Purpose

This policy establishes minimum requirements for passwords and multi-factor authentication (MFA) to reduce the risk of unauthorized account access.

2. Scope

This policy applies to employees, contractors, administrators, service accounts, and users accessing SecurePay systems, applications, cloud services, VPN, email, and other organizational resources.

3. Password Requirements

- Use passwords that meet the organization's defined minimum length and strength requirements.
- Do not reuse organizational passwords across unrelated services.
- Do not share passwords with other people.
- Do not store passwords in plaintext or in unapproved locations.
- Avoid predictable passwords based on names, company information, or commonly used patterns.
- Use an approved password manager where provided.

4. Password Storage

Applications must not store passwords in plaintext. Passwords should be protected using industry-accepted password hashing and appropriate security controls.

5. MFA Requirements

- MFA should be required for privileged accounts.
- MFA should be required for remote access such as VPN.
- MFA should be enabled for externally accessible and high-risk applications.
- Cloud administration and other sensitive services should use MFA.
- Users must not approve unexpected authentication prompts.

6. Account Lockout & Monitoring

- Systems should apply reasonable controls against repeated failed authentication attempts.
- Suspicious authentication activity should be logged and investigated according to security procedures.

- Account lockout settings should balance security with operational needs.

7. Password Reset

- Password resets must use an approved identity verification process.
- Temporary credentials must be changed after first use where applicable.
- Users should report suspected credential compromise immediately.

8. Compromised Credentials

If a password or authentication factor is suspected to be compromised, the account should be secured promptly. Relevant sessions or tokens may be revoked, credentials reset, and security monitoring increased as appropriate.

9. Responsibilities

- Users: protect credentials, use MFA correctly, and report suspected compromise.
- IT/IAM: configure authentication controls, manage resets, and monitor authentication security.
- Security Team: define security requirements and investigate suspicious authentication activity.
- Managers: support timely access changes when roles or employment status change.

10. Exceptions

Exceptions must be formally documented, approved by the appropriate owner, time-bound, and supported by compensating controls where feasible.

11. Review

This policy should be reviewed annually or following significant changes to authentication technology, threats, or organizational requirements.